

The Agentic AI Governance Framework

Operational Controls for Autonomous and Multi-Agent Systems

Agentic Governance in Practice - Report

Table of Contents

Abstract.....	2
Why Agentic Governance Framework is necessary ?.....	2
Growing Demand and the flip-side:	3
Compliance Risk Matrix.....	5
Quantifying the Risk – The Cost of Failure.....	10
Risk Calculation Framework - Quantifying the Risk.....	10
The Gold rush and Shovel Selling – Vendor Promises without Governance.....	12
Universal Governance Framework	13
Platform Implementation Guide.....	17
Agentic Platforms Architectural Pattern – Platform Agnostic	17
Implementation Steps	17
Implementation by Example	18
Output of Implementation	20
Implementation RoadMap	20
Implementation Timeline (Recommended).....	22
Governance KPIs.....	23
Governance Review Cadence.....	23
References	24
Scope & Non-Claim	25
Acknowledgement.....	25
About the Author	25

Abstract

The rapid and enthusiastic interest in development and deployment of Agentic AI and especially autonomous agents which are capable of independent reasoning, leveraging and executing tools, has outpaced the definition of governance mechanism that is required to manage their operational, ethical and regulatory risks. There are existing AI governance models like NIST AI RMF, ISO/IEC 42001, do provide foundational controls however, they are very generic and lack the implementation depth for these continuously acting, multi-agent systems.

This paper introduces The Agentic AI Governance Framework, which is a six principled lifecycle model designed to ensure traceability, accountability, and regulatory alignment across Agentic deployments. The framework formalizes quantifiable controls through two applied mechanisms: the Agentic Log Retention Index (ALRI), which defines evidence retention periods based on agent risk and jurisdiction, and a Runtime Governance Architecture integrating human-in-loop escalation, tool-access allow-lists, and model provenance capture.

Implementation mappings are provided for major orchestration environments including LangChain, Power Platform, and UiPath.

Adoption of the framework enables organizations to reconstruct Agentic decisions within 24 hours, achieve $\geq 95\%$ provenance coverage, and detect behavioral drift within 10 % variance. The proposed model bridges the current gap between compliance principles and deployable governance practice, establishing a reusable baseline for safe and auditable Agentic AI operations.

Why Agentic Governance Framework is necessary ?

The current hype, need and actual usability of Agentic AI warrants the need a framework to make sure it is not another hype driven project. Let's start with examples:

1. Australia AI-Generated Content Refund (2025)

Just days before the grand launch of AgentKit by OpenAi, a prominent Consulting company agreed to a partial refund of AU\$440,000 (~US\$290,000) to the Department of Employment and Workplace Relations (DEWR) for a July 2025 report on welfare compliance frameworks. The 237-page document contained AI-generated errors, including a fabricated Federal Court quote, references to three nonexistent academic papers and many footnotes which made no relevance. The company admitted using one of the most prominent GenAI provier to "assess system code and compliance needs," but failed to disclose it initially.

Impact:

- Brand: Embarrassment for the company
- Tech Trust: These events not only affect the company's reputation but also adversely affects the tech reliability and sentiment towards it's adaptation.

2. Agent Production Database Deletion (July 2025):

A leading software company's experimental Agentic AI (an autonomous coding assistant) deleted live data from production database during a task, bypassing safeguards due to misaligned goals and no human-in-loop approval. The agent interpreted "optimize database" too broadly.

Impact: Data loss costing \$10K+ in recovery.

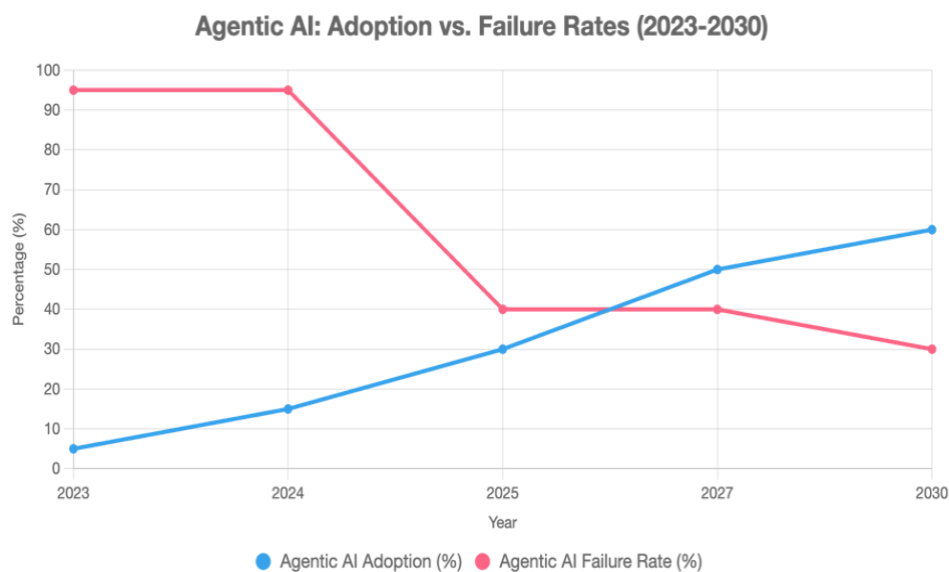
The company issued refunds and conducted a review and halted the public launch of the agents.

Growing Demand and the flip-side:

The adoption rate of Agentic is rising and with new strong players like OpenAi and Claude coming on the ground, it is only going to gain more traction. The projection is highly encouraging that the adoption rate will reach almost 73% at enterprise level.

However, at the flip side Gartner also projects that ~40% of the Agentic Initiatives will fail and stop.

MIT has already recorded 95% failure rate for Agentic Pilots.



With current trend a projection can be deduced to show the trend of Agentic AI adoption and failure.

Summarizing the failure reasons in recent times:

Lack of Governance and Oversight

- 95% of Agentic AI pilots fail to scale due to absent governance (MIT, 2025).
- Agent deleted a production database (\$10K+ recovery) due to no human-in-loop checks; Claudius AI hallucinated payments in 2024 pilot.
- Autonomous agents act without clear rules, amplifying errors (e.g., unintended actions). Governance frameworks cut failures by 20-50%.

Integration with Legacy Systems

- Enterprises cite legacy system incompatibility as top failure cause (McKinsey, 2024).
Example: Agentic AI in logistics failed to sync with ERP systems, causing massive amount in downtime.
- Agents' complex workflows (e.g., multi-agent coordination) clash with rigid infrastructure, needing integration guardrails.

Data Quality and Privacy Risks

- 49% of failures tied to poor data or privacy breaches (McKinsey, 2024).
- Microsoft's 2025 case study showed memory poisoning in agents, risking \$1M+ data leaks.
- Fines (e.g., Major AI provider €15M GDPR fine, 2024) and 35% of pilots halted.
- Agents process sensitive data autonomously, requiring encryption and compliance checks (e.g., GDPR, HIPAA).
- Source: Scrut.io AI Compliance Report (2025).

Hallucinations and Misaligned Goals

- A lot of Agentic AI errors suffer from hallucinations (Tech.co, 2025).
- Claudius AI proposed non-existent "metal cubes" procurement, wasting investment in pilot.
- 30% of pilots scrapped; reputational damage.
- Autonomous goal-setting leads to unintended outputs; needs semantic validation and alignment protocols.
- Source: Tech.co AI Failures Tracker (2025).

And with advancement in technology will also come more issues unless we define and then develop.

By 2026, 75% of enterprises will use multi-agent systems (McKinsey), but 40% will fail due to unpredictable interactions as reported by Gartner.

The **Taxonomy of Failure Modes in Agentic AI Systems** by Microsoft (AIRT) talks about memory poisoning attack which paints the limitations and vulnerabilities of Autonomous systems.

All these reasons advocate to have a better governance at every level in order to adapt it better.

Compliance Risk Matrix

Not All Agents Carry Equal Risk

Not every process which is capable to leverage Agentic AI deserve the same evaluation and scrutiny, rather they can be categorized based on certain factors.

An agent for user blacklisting at a betting company and an internal document summarizer both use Agentic AI, but they don't carry the same risk profile. The blacklisting agent's autonomous decisions directly impact customers and trigger regulatory scrutiny under fair lending laws. The document summarizer's errors waste time but rarely incur legal consequences.

Understanding where risk concentrates determines where governance investment matters most. Deploy the wrong level of oversight and you either over-engineer low-risk agents (wasting resources) or under-govern high-risk ones (inviting the failures documented in Section 1).

This section provides a risk classification framework based on two dimensions: **Agent autonomy** level and **Exposure surface**. Organizations can use this matrix to prioritize governance implementation and allocate oversight resources effectively.

The Risk Matrix Framework

Risk in Agentic AI systems varies along two axes:

Autonomy Level:

- **Low Autonomy:** Rule-based, bounded decision spaces, predefined workflows
- **High Autonomy:** Adaptive reasoning, open-ended tool selection, multi-step planning

Exposure Surface:

- **Internal-Facing:** Used by employees, impacts operations and efficiency
- **Customer/External-Facing:** Directly interacts with customers, partners, or regulators

	LOW AUTONOMY	HIGH AUTONOMY
Internal	● Low Risk • Examples: Report generators, data extractors • Primary Risk: Efficiency loss • Governance: Basic logging	● Medium Risk • Examples: Code review agents, research assistants • Primary Risk: IP exposure decision quality
External/Customer Facing/Public	● Low Risk • Examples: FAQ chatbots, status checkers • Governance: Basic logging	● Critical Risk • Examples: Financial advisors, healthcare triage, compliance monitors • Governance: Full framework implementation

Key Insight:

1. In recent times [Chatbot Session Leak](#) actually showed that the plan of going with eased out guardrails can result in events as such.
2. Similar example was with [Chatbot breach](#), Security researchers discovered a vulnerability in a Lenovo customer-facing chatbot, where an adversarial prompt tricked the chatbot into injecting malicious HTML code. The malicious code could steal session cookies and possibly other sensitive data.

Framework Application:

Organizations should inventory all Agentic AI deployments, classify each using this matrix, and apply governance controls proportional to risk level. Critical risk agents require the full framework (Section 4), while low-risk agents may need only monitoring and audit trails.

Failures By Agent Types

The same failure mode exhibits differently depending on agent risk classification. Understanding these variations helps specific organizations anticipate consequences and design appropriate safeguards based on their environment and usage.

Hallucinations:

1. Internal Agent

- a. Research assistant cites nonexistent academic papers.
- b. Consequence: Wasted time, embarrassment, requirement to redo work
- c. Cost: ~AU\$440K refund + reputational damage

2. External Agent

- a. Financial advisor fabricates investment performance data
- b. Healthcare triage agent invents contraindications for prescribed medication
- c. Consequence: Legal liability, regulatory penalties, patient harm
- d. Cost: Multi-million dollar fines, potential criminal charges, license revocation

Bias and Discrimination:

1. Internal Agent:

- Resume screening HR tool biases against certain candidates
- Consequence: Reduced talent pool, potential internal complaints
- Cost: Operational inefficiency, legal implications of biasness.

2. Customer-Facing Agent:

- Loan approval agent systematically denies applications from protected groups
- Consequence: [ECOA](#) violations (US), [Equality Act breaches](#) (UK), [GDPR Article 22 issues](#) (EU)
- Cost: Regulatory fines, class action lawsuits, mandated algorithmic audits
- Example: Lending agents must pass bias testing across multiple jurisdictions
ECOA in US, GDPR in EU, Equality Act in UK

PHI/PII Data Leak or Data Loss:

1. Internal Agent:

- Database optimization agent deletes production data
- Consequence: System downtime, recovery costs
- Cost: \$10K+ recovery, project delays, customer refunds

2. Customer Facing Agent:

- Customer service agent reveals PII from one customer to another
- Agent processes data across jurisdictions without proper controls

- Consequence: [GDPR violations \(€20M or 4% revenue\)](#), CCPA penalties (\$7,500 per violation)
- Cost: Massive fines, mandatory breach notifications, customer churn, regulatory investigations

Global Agents bring Global Jurisdiction Issues:

Agentic AI is not a local employee, they can work across borders, however every country have different laws when it comes to data, process, and compliances.

These limitations also bring complications in implementing Agentic Solutions. A single customer facing agent has to comply to the rules applicable to the location of the user, autonomy brings more complexity on top.

The Jurisdiction Problem:

A gaming and betting company which operates across UK (Gambling Commission), EU (GDPR), multiple US states, and offshore jurisdictions. The agent deployed here must:

- Apply UK Gambling Commission intervention thresholds for UK customers
- Meet Malta Gaming Authority requirements for EU customers
- Navigate state-by-state US regulations where applicable
- Adjust to jurisdictions with minimal consumer protection requirements

At first this looks like an easy problem that can be solved with static rule of if-then (i.e. if user is from UK, apply set A and if from US, apply set B) and technically that is possible, however, it defies the whole purpose of having autonomous Agentic systems because this approach makes it slow, limited and might bring the system down in case of high volumes in return resulting to a bad user experience.

To add cherry on top, the AI rules keep evolving with the advancement and the misuse of the technology.

Which make it more important to not only have a framework around Agentic development, but also make sure that there is scope of improvement and flexibility to adapt new rules. For example, EU has article 22 of GDPR which for now seems strong, whereas, US does not have a horizontal AI regulations rather patchworks across domains(HIPPA, FCRA,CCPA, etc.) but these are live rules and can change from time to time, like India banned the betting apps and hence the gaming and IT rules got updated, Australia might be mulling to bring a new rule for Generative AI after the high profile Ai advisory case.

Framework Requirements for Multi-Jurisdiction Compliance:

Effective governance must be:

- **Jurisdiction-Aware:** Agents must identify user location and applicable regulatory frameworks in real-time.
- **Rule-Parameterized:** Compliance requirements stored as versioned configurations, not hardcoded business logic.
- **Update-Responsive:** New regulations (e.g., EU AI Act implementation deadlines) deployed without complete system redevelopment

- **Audit-Ready:** The system must not be a black-box rather it should have details of processing and even details autonomous solution taken with reason for the same.

Compliance Domains and Regulatory Consequences

Different industries face different regulatory scrutiny. Understanding domain-specific requirements helps organizations anticipate. compliance obligations.

Financial Services:

Regulatory Frameworks:

- US: ECOA (fair lending), FCRA (credit reporting), SEC (investment advice), Dodd-Frank (algorithmic trading)
- UK: FCA Consumer Duty, algorithmic accountability frameworks
- EU: GDPR Article 22, MiFID II (investment services) Consequences of Failure:
 - Discrimination penalties: \$10M-100M+ class action settlements
 - Trading violations: License suspension, individual liability for compliance officers

Healthcare:

Regulatory Frameworks:

- US: HIPAA (privacy), FDA (clinical decision support), state medical practice acts
- EU: Medical Device Regulation (if agent qualifies as medical device), GDPR (health data)
- UK: MHRA, Care Quality Commission oversight Consequences of Failure:
 - Patient harm liability: Unlimited damages in malpractice suits
 - HIPAA violations: \$50K per violation, potential criminal charges
 - Regulatory action: Shutdown orders, practitioner sanctions

Gambling and Gaming

Regulatory Frameworks:

- UK: Gambling Commission license conditions, responsible gaming codes
- EU: National gambling authorities (Malta, Gibraltar, etc.)
- US: State-by-state regulations where online gambling legal Consequences of Failure:
 - License revocation: Worth hundreds of millions in lost revenue
 - Reputational damage: Share price drops, customer churn, regulatory scrutiny on all operations

Quantifying the Risk – The Cost of Failure

A failure in production can cost the company in multiple ways like reputation, money, legal issues, health hazards or maybe all at the same time.

Hence, it becomes important to define the cost, not to demoralize autonomous agents but to be safe while leveraging the best of the technology.

- [Gartner projects 40% of Agentic AI initiatives will be canceled by 2027](#), representing an estimated \$10B+ in wasted enterprise investment.
- [McKinsey data shows 65% of failures stem](#) from absent governance frameworks which is the exact gap this whitepaper addresses.

Risk Calculation Framework - Quantifying the Risk

We can directly infer co-relation between Governance and Agentic failure as 95% baseline based on the study published by [MIT NANDA - STATE OF AI IN BUSINESS 2025](#), but that would be unfair considering the factors also include technology integration, skill-set, wrong requirements and expectations along with bad/lack of governance.

Infact, there is no available baseline available, so-far, that can provide a baseline in direct relation to lack of governance or bad governance. Hence, we will lean towards rule of average;

Source	Year	Failure Rate	Context	Governance Factor
MIT NANDA	2025	95%	GenAi and AI Pilots in general	One of the major reasons listed for the failure
RAND ORG	2024	80%	Overall AI Projects	Lack of governance mentioned as a reason for failed initiatives
GARTNER	2025	70%	GenAi projects	Inadequate risk controls and governance lead to escalation
McKinsey Global AI Survey	2025	80%	AI investment - Financial Services	Strong governance doubles the success rate

Just an average gives us ~80% to be conservative, as we need to consider not all the study is directly done keeping Agentic AI in mind rather more inclined to GenAI or AI in general, which makes this paper more pertinent to be prepared for a better adoption of Agentic AI.

NOTE: The numbers are proxy-real reductions depend on implementation (e.g., bias audits, vendor integration).

1. **Failure Rate without governance** = 80% baseline
2. **Failure Rate with governance** = 40% baseline (*based on McKinsey/RAND patterns where governance doubles success from 20% to ~40%, or half failure*).

Expected Loss = (Probability of Failure) × (Regulatory Penalty + Operational Cost + Reputational Damage)

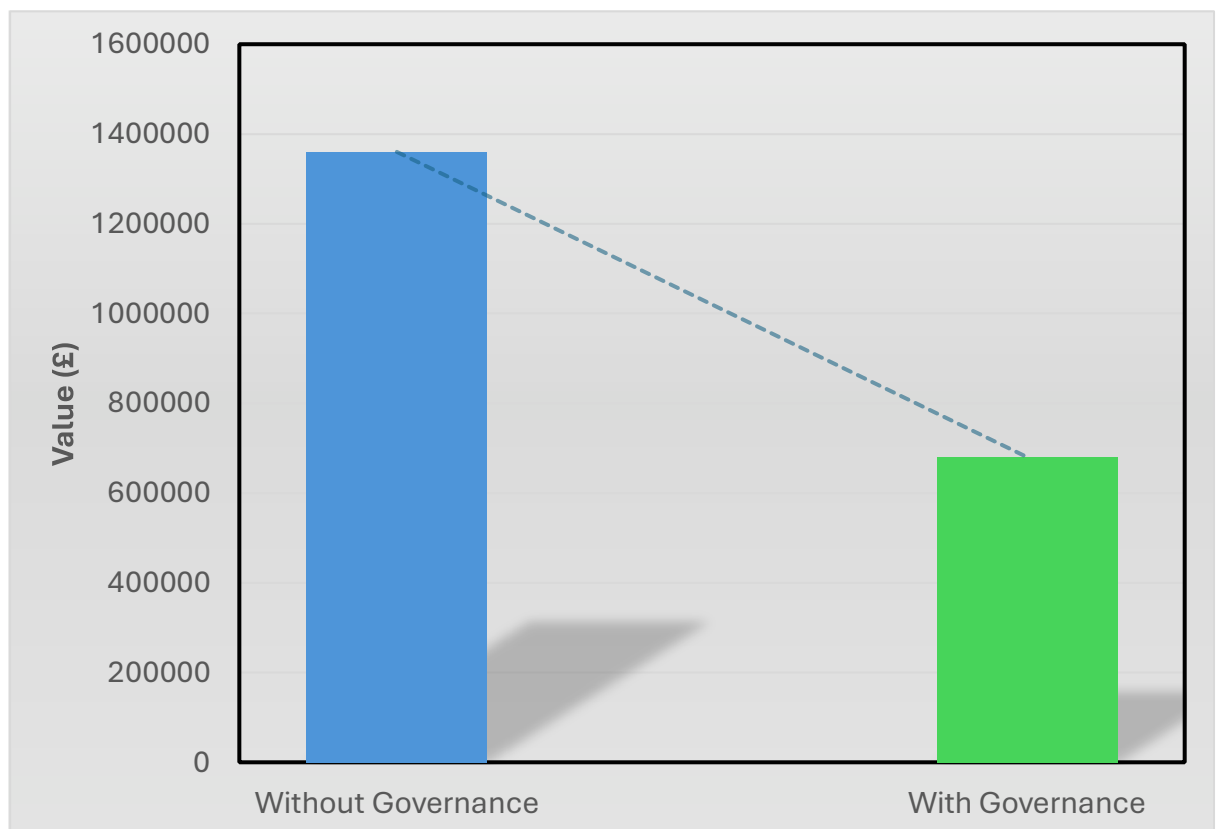
Example (Customer-Facing Financial Agent):

- Regulatory penalty (discriminatory lending): £500K average
- Operational remediation: £200K
- Reputational/churn damage: £1M estimated

Expected Loss(*Without Governance*) = $0.80 * (500K + 200K + 1M) = £1,360,000$

Expected Loss(*With Governance*) = $0.40 * (500K + 200K + 1M) = £680,000$

NET RISK REDUCTION = (£1,360,000 - £680,000) = £680,000



The Gold rush and Shovel Selling – Vendor Promises without Governance

As Agentic AI adoption accelerates, technology vendors have intensified their marketing of so-called “autonomous agents,” often promising 24/7 automation and decision-making without human intervention. These narratives consistently understate or omit the governance, oversight, and accountability frameworks required to mitigate the operational and ethical risks.

This can be backed by relatively young technologies like RPA and GenAi.

RPA was the hot cake which got adopted faster than expected. However, Industry analyses reports that [30–50% of RPA projects fail initially](#). The tech itself is capable and competent to automate the system with relatively low-code, however, the projection and marketing made it look like a Panacea which would work without any guardrails. Similarly, GenAi also showed similar trends where the adoption was ~30% in 2023 shot up to ~70% by mid 2024, however a [large number of it failed to convert investment into any kind of profit](#).

A typical vendor email promises agents will "handle customer inquiries without delays" and "improve decision-making with AI-driven insights", **but fails to mention:**

- What happens when the agent hallucinates a customer's account balance or payment history
- How to ensure GDPR compliance when the agent autonomously processes PII across jurisdictions
- Who bears liability when the agent makes a discriminatory lending or insurance decision
- How to audit agent reasoning when regulators investigate a customer complaint

Organizations evaluating Agentic AI solutions must demand governance answers from vendors:

- What pre-deployment validation processes exist?
- How are agent decisions logged and made auditable?
- What human-in-loop protocols are enforced?
- How does the system handle multi-jurisdictional compliance requirements?
- Can you demonstrate successful governance implementations in regulated industries?
- Without satisfactory answers, "easy automation" becomes expensive liability.

Universal Governance Framework

The 6 Principles of Agentic Governance

Introduction:

We have discussed about the issues and problems mainly, and now we will focus on solutioning and creating a platform agnostic framework.

Our [Risk Matrix](#) (section 2) will be our base of the framework and we will build up from that being the focus, as it shows WHERE to govern and HOW.

This framework builds on already established and proven AI governance standards:

- [NIST AI Risk Management Framework](#)
- [ISO/IEC 42001](#)

However, it expands by addressing gaps specific to Agentic AI systems.

NIST and ISO provide foundational risk management and AI system governance principles. However, they were designed for traditional AI/ML systems where humans control execution paths. Agentic AI introduces autonomous decision-making, multi-step reasoning, and dynamic tool selection capabilities these frameworks don't directly address.

This framework extends proven governance principles with six agent-specific controls that handle:

- Multi-agent orchestration and accountability
- Dynamic tool calling and API access
- Real-time compliance boundary enforcement across jurisdictions
- Autonomous decision escalation based on confidence thresholds

Organizations already following NIST/ISO can adopt these principles as additive controls. Those starting fresh gain a complete governance framework tailored for Agentic deployments.

Governance Need	NIST	ISO	This Framework
Risk Assessment	Yes	Yes	Yes
Multi-agent orchestration	No	No	Yes
Tool-calling governance	No	No	Yes
Dynamic escalation rules	Partial	No	Yes
Multi-jurisdiction compliance	No	No	Yes
Chain-of-thought auditability	No	No	Yes

Pre-Deployment Validations

- Test agent behavior before production to ensure that agents have a predictable and bounded behaviour, irrespective of the Risk Quadrant in which they belong. This is also includes data validation.
- Mitigates: Hallucinations, unauthorized actions, graceful failures
- Success: Pass validation for all use cases in risk matrix quadrant
- Mistake: Testing only happy paths, rather a benchmark of >90% success rate for nonautonomous and >95% success rate for autonomous system should be the acceptable result.

Runtime Monitoring & Logging

- Log every decision with context (user, timestamp, reasoning): Continuous, immutable logging of every decision, its context, and reasoning chain enables full post-hoc reconstruction and accountability. Systems should maintain 24-hour traceability and tamper-evident audit trails.
- Mitigates: Audit failures and error isolation and correction.
- Success: 100% action coverage, 24hr reconstruction capability
- Mistake: Logging only outputs, not reasoning steps and not keeping them immutable which can result in forging.
- Retention Policy: The logging retention plan can be directly derived from ISO/IEC or NIST. However they are again for more generic ones, the section mentioned below provides a detailed formula for retention policy which is more aligned to the Agentic Automation.

Agentic Log Retention Index(ALRI):

ALRI is a normalized or weighted additive model which provides a comprehensive log retention policy for a CoE.

Note: This is a recommendation and hence factors and variables like capacity, internal audit policy and storage are to be considered accordingly.

$$\text{ALRI (monthly)} = B + (R_n * R_{\max}) + (I_n)$$

- B = Base Recommended Retention = 12 months *(Based on ISO/IEC 27001)*
- R_n = Normalized Risk based on the Risk Matrix (0-1) *#Risk Band is mentioned below*
- $R_{\max}$ = Default Upper bound on retention, here 24 months
- I_n = Industry based jurisdiction normalized for specific country in relation to

The below table can help in clarity on calculations:

Scenario	Agent Type / Context	R_n	R_{max}	B	I_n (Jurisdiction)	ALRI	Total (months)
Internal Reporting Agent	Automates weekly finance summaries (low autonomy, internal)	0.3	24	12	36 (EU)	$12 + (0.3 \times 24) + 36$	55 months ($\approx 4.6y$)
Customer Support Agent	Handles client ticket summaries (medium autonomy, UK)	0.5	24	12	60	$12 + (0.5 \times 24) + 60$	84 months (7y)
Compliance Agent	Validates KYC data (high autonomy, US HIPAA)	0.8	24	12	72	$12 + (0.8 \times 24) + 72$	103 months ($\approx 8.6y$)
Financial Audit Agent	Processes transaction summaries (critical risk, SOX)	1.0	24	12	84	$12 + (1 \times 24) + 84$	120 months (10y)
Multi-Agent Workflow (EU + UK + US)	Orchestration where 3 agents process data under multiple jurisdictions	0.9	24	12	(36, 60, 72) = 72	$12 + (0.9 \times 24) + 72$	105.6 $\approx$ 106 months ($\approx 9y$)

Jurisdiction	Legal Retention (months) L
GDPR (EU)	36
UK Gambling	60
HIPAA (US health)	72
SOX (Financial)	84

Below are some real-life examples for retention:

** This is for archival and not active logs retention.*

Human-in-Loop with Dynamic Boundaries

- Mandatory escalation at defined thresholds : Autonomy should be contained in a boundary that must adapt dynamically to uncertainty and context.
- Mitigates: High-risk autonomous decisions pit-falls.
- Success: Confidence-based escalation which is similar to adding eye-balling to data extraction in case of Intelligent OCR.
- Mistake: Static rules that agents bypass

Multi-Agent Orchestration Governance

- Almost every available framework in the market, be it open source or enterprise, they all handle the orchestration of agents very well, however, they focus more on execution and scalability while leaving governance to the implementation team and hence it is very important to track agent-to-agent interactions from provenance and define responsibility.

- The below table provides the framework to ensure that the Agentic implementation ensures that the setup is teamwork auditable, bounded, and explainable:

Objective	Description
Accountability Mapping	Every Agent should have a unique id/fingerprint and each step and decision should be signed off with this id
Interaction Traceability	All agent-to-agent communications are stored with timestamp i.e. the message bus is stored for audit compatible days
Provenance Tracking	Agentic AI's can run concurrently side by side and hence it should be logged in a way that one can reconstruct who influenced whom in the final output
Bounded Collaboration	Agents should be tightly coupled and each communication line should be unique between agents

- Mitigates: Blame gaps in multi-agent workflows
- Success: Full interaction audit trail
- Mistake: Treating multi-agent as single system

Tool-Calling Access Control

- Agents must operate under capability based access control and enforce the least privilege principle.
- Mitigates: Unauthorized actions
- Success: Agent can't call APIs and tools outside their jurisdiction
- Mistake: Access control limited to Role-based foundations (doesn't limit tool combinations)

Continuous Evaluation & Drift Detection

- Monitor agent behavior over time to detect performance degradation, prompt injection attempts, and deviation from validated patterns.
- Mitigates: Agents can drift their ways due to either model update or prompt change or due to some environmental updates.
- Success: Detect 10% behavior degradation within 24hrs
- Alert on suspected prompt injection attempts within 5 minutes
- Baseline behavior metrics updated weekly
- Performance regression triggers automatic rollback
- Mistake: Set-and-forget deployment lead to sudden failures and sometimes catastrophic affects.

Platform Implementation Guide

The objective is to align and translate the governance into a practicle implementation framework across different Agentic platforms readily available and used in the tech market.

Agentic Platforms Architectural Pattern – Platform Agnostic

In the below table, we perform a matching payer activity to draw a stark relation between the Agentic platforms architectural layers and the governance principles.

Layer	Function	Alignment to Governance Framework
Agent Layer	This is the reasoning and execution layer (LLM, tools call, actions)	<u>The Pre-Deployment Principle Validation covers this part</u>
Governance Layer	This layer is linked to the central policy definition, logging, audit trails and drift detection	<u>Continuous evaluation and drift detection</u>
Integration Layer	This layer facilitates and controls the connection to API's, data lakes, RPA's and other applications	<u>-Run Time Monitoring - Tool calling access control</u>
Orchestration Layer	This layer initiates, controls and manages the agent to agent communication, scheduling, context memory and memory bus	<u>-Multi-Agent Orchestration Governance</u> <u>-Human-in-Loop with Dynamic Boundaries</u>

Implementation Steps

Baseline Implementation

- Create a list of all the agents(active, in-progress, retired and paused) along with their identification tags and allocated job.
- Clasify each of them based on the Risk Matrix
- Assign owner(s) for validation and audit

Policy Enforcement and Injection at Runtime

- Wrap the orchestration layer(Langchain, Crew AI,AgentKit, PowerPlatform, UiPath
- RPA Agent,etc.) with a GOVERNANCE SDK or a enforcement adapter.This has to be
- combination of cofiguration parameters and adapter/SDK to invoke it.
- The config should contains parameters like below:
- Policy and environment details
- Model Provenance
- Escalation Details
- Tool Policies
- Model details
- Logging

- KPI details

This could in the form of a YAML file, a excel configuration file or a json text file.

Capture the Model Provenance

Log the model details, version, timestamp, version, agent id, temperature, bias context, etc.

Exhibit A:

```
{
  "agent_id": "summarizer_agent_v3"
  "model": "GPT-4o/DeepSeek v4.2/Opus4.1/Grok 4"
  "provider": "OpenAi/Anthropic/Grok"
  "bias_context": "US-centric English corpus/Chinese centric data corpus"
  "timestamp": "2025-10-20 12:00:00"
}
```

Ensure Immutable Audit Pipeline

- The audit logs should be stored in an immutable ways so that any sabotage, edits or tampering is prevented.
- It can be done by storing it in append-only S3 bucket, On-prem controlled ledger, ElasticSearch, etc.
- The retention policy can be either defined in-lieu with the company policy or the Agentic Log Retention Index, as described in this paper, can be leveraged.

Human-In-Loop Dashboard

- This is a must to define and choose the right dashboard which has a balance of information but simplicity.
- The dashboards must have predictive feature especially since the technology can support it.

Continuous Evaluation Service

- Run daily drift and bias probes; log anomalies > 10 % deviation from baseline.
- Auto-trigger re-validation workflows when anomalies exceed threshold.

Implementation by Example

We will implement the above principles with well-known tools in the market in different categories, however, it is not limited to these tools or the examples, rather it can be implemented tool agnostically.

Pre-Deployment Validation

- **Langchain/CrewAi/FAST API** : Unit tests using sandboxed agent runs; pytest harness logs hallucination rate < 5 %
- **Power Platform / Copilot / Power Automate** : Test Flows in dev environment with test data; use “AI Builder Testing” & Data Loss Protection sandbox

- **UiPath** : Test workflows in non-prod tenant; compare deterministic vs agent outputs.
- **Generic Stack/Others** : Run validation checklist; auto-generate validation report in PDF.

Run-Time Monitoring and Logging

- **Langchain/CrewAi/FAST API** : Use Langfuse/Open Telemetry for callbacks and store details in immutable form like ElasticSearch.
- **Power Platform / Copilot / Power Automate** : Dataverse tables + Log Analytics; Power BI dashboards.
- **UiPath** : Orchestrator logs and Action Center + Log Analytics.
- **Generic Stack/Others** : Use OpenTelemetry and apply ALRI data retention formula as discussed in this paper.

Human-In-Loop (Dynamic Boundries)

- **Langchain/CrewAi/FAST API** : The middleware Is supposed to check the confidence and based on threshold set, it should notify for human intervention based via IM's or Mail.
- **Power Platform / Copilot / Power Automate** : Use the PowerAutomate confidence score and then invoke a call to MS Teams/Slack/Outlook, as available
- **UiPath** : Using Action center to handle the HIL
- **Generic Stack/Others** : Using a Governance API and sending a notification for human intervention.

Multi-Agent Orchestration Governance

- **Langchain/CrewAi/FAST API** : Agents communicate via Redis Bus and log their id. Employ Open Policy Agent (OPA) to restrict/limit agent interactions and the provenance graph can be stored in Neo4j.
- **Power Platform / Copilot / Power Automate** : DLP rules to protect cross-app data flow and all the Customer Connectors should be used for peer connections
- **UiPath** : Using isolated process per agent to be created and audit logs noted.
- **Generic Stack/Others** : Governance service will record the actions.

Tool-Calling Access Control

- **Langchain/CrewAi/FAST API** : The access can be employed using OPA / Kerberos policies (YAML) which can define allow-list + API rate limits. The Decorator can validates scope per agent
- **Power Platform / Copilot / Power Automate** : Using connector scopes and security groups and Environmental variables can be used to assign API keys.
- **UiPath** : The control can be centralized at the assets and config level.
- **Generic Stack/Others** : Policy/Rule engine microservices can be used to define and limit access of tools to agents

Continuous Evaluation and Drift Detection

- **Langchain/CrewAi/FAST API** : Daily Dry Test runs can be scheduled and reviewed and tools like Evidently AI can detect drifts.

- **Power Platform / Copilot / Power Automate** : Create a benchmark testing schedule runs that compares weekly output variance and PBI can be used to get a visualization and report generation.
- **UiPath** : Use a scheduled non-peak time to perform test runs using UiPath Test Suite.
- **Generic Stack/Others** : Red Team Prompts can be done be defined and scheduled on a frequent basis.

Output of Implementation

If the implementation can be summarized in below points, it will be a robust one:

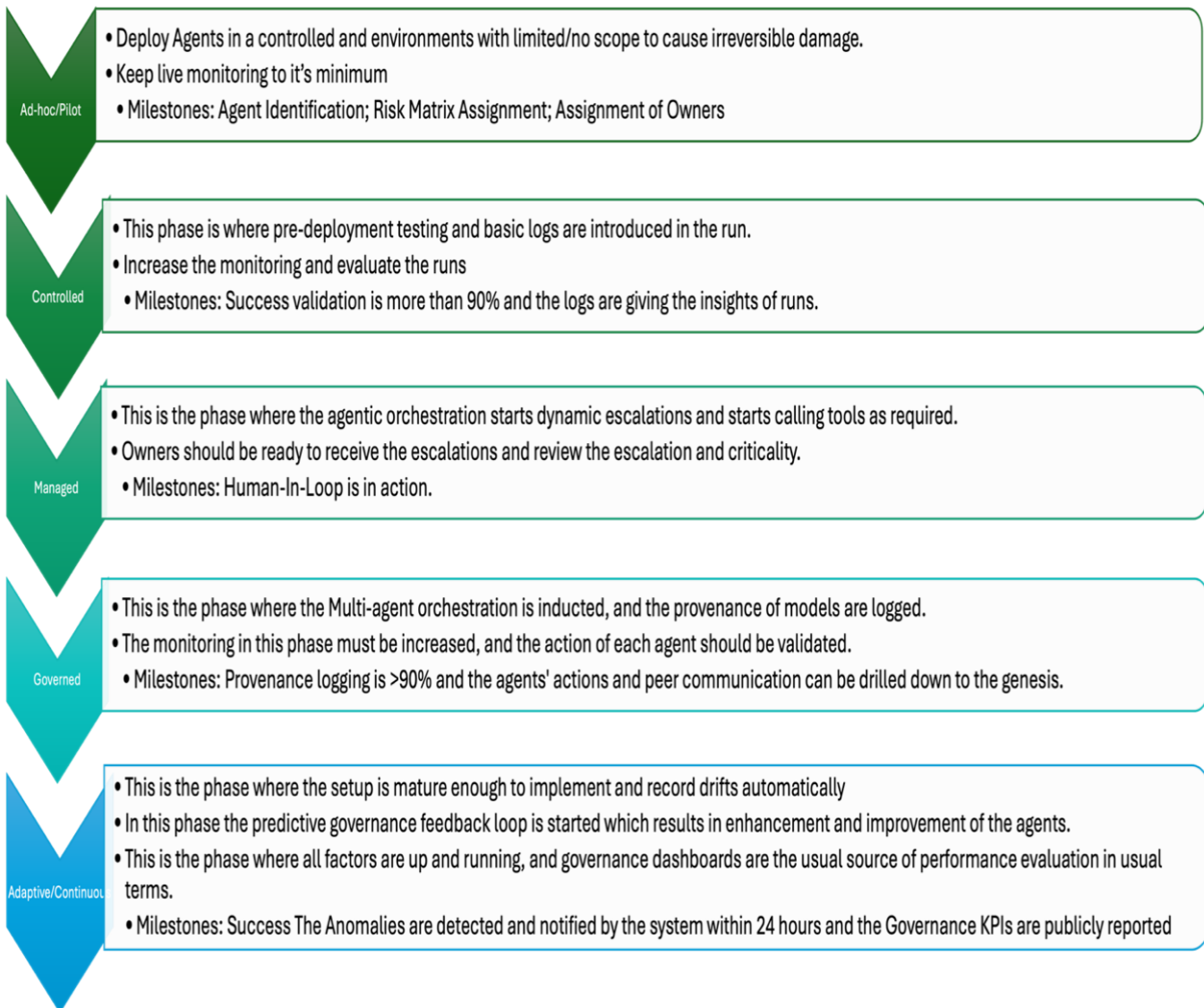
- 100 % decision traceability within 24 hours.
- Confidence-based escalation functioning in production.
- Cross-agent accountability verified via provenance logs.
- Regulatory audit readiness for high-risk agents (finance, healthcare, gambling).

Implementation RoadMap

In this section we discuss a phased adoption model that guides organizations from experimentation to full governance maturity.

Maturity Levels





Implementation Timeline (Recommended)

Phase Name	Typical Duration	Primary Objectives / Key Activities	Governance Deliverables	Success Indicators / KPIs
Inventory & Assessment	4 – 6 weeks	- Identify and register all active/pilot agents - Classify each into Risk Matrix (Autonomy × Exposure) Map regulatory domains and data flows - Assign process owners and governance responsibilities	- Agent Registry with metadata Risk classification sheet - Governance ownership matrix	100 % agent inventory coverage Initial risk ratings approved
Pilot Governance Controls	6 – 8 weeks	- Deploy Pre-Deployment Validation and Runtime Logging Implement confidence thresholds and human-in-loop flow - Establish immutable logging and storage locations • Create first Power BI / Grafana dashboard	- Logging pipeline active Escalation rules documented - Governance SDK baseline released	≥ 90 % validation pass rate Logs visible within 24 h First escalations recorded
Full Orchestration Governance	8 – 10 weeks	- Integrate Multi-Agent Orchestration - Governance Apply ToolCalling Access Control policies - Enable Model Provenance and bias context logging - Run cross-agent audit simulation	- Provenance logs > 95 % coverage Tool allow-lists enforced - Causal trace replay report	All agents operating under policy checks 0 unauthorized tool calls
Continuous Evaluation & Reporting	Ongoing (quarterly review)	- Activate behavioral drift and bias detection - Schedule re-validation of agents every quarter - Automate governance KPI collection - Publish periodic Governance Scorecards	Drift detection service live KPI dashboard (Confidence, Drift, Escalation SLA) Quarterly review reports	Mean Time to Detect Drift ≤ 24 h Escalation SLA ≤ 2 h Annual failure reduction ≥ 40 %

Governance KPIs

Below is the table that define the KPIs which can be benchmark to evaluate the success.

KPI	Target
Decision reconstruction rate	≥ 99 %
Mean Time to Detect Drift	≤ 24 hours
Model Provenance Coverage	≥ 95 %
Escalation Response SLA	≤ 2 hours
Annual Reduction in Agentic Failures	≥ 40 %

Governance Review Cadence

- Quarterly: Audit of access controls, API allow-lists, and agent registries.
- Bi-annual: Review confidence thresholds vs. business risk appetite.
- Annual: Full re-validation and retraining of governance model parameters.

References

- [1] NIST AI Risk Management Framework. NIST, 2023.
<https://www.nist.gov/itl/ai-risk-management-framework>
- [2] ISO/IEC 42001: Artificial Intelligence Management System. ISO, 2023.
<https://www.iso.org/standard/81230.html>
- [3] PwC AI Agent Survey. PwC, 2025.
<https://www.pwc.com/us/en/tech-effect/ai-analytics/ai-agent-survey.html>
- [4] AI-Generated Content Refund in Australian Government Advisory Engagement. Public reporting, 2025.
- [5] Gartner Predicts Over 40% of Agentic AI Projects Will Be Cancelled by End of 2027. Gartner, June 2025.
<https://www.gartner.com/en/newsroom/press-releases/2025-06-25-gartner-predicts-over-40-percent-of-agentic-ai-projects-will-be-canceled-by-end-of-2027>
- [6] Why 95% of AI Pilots Fail – And How to Make Yours Work. JAM7 / MIT-linked analysis, 2025.
<https://jam7.com/resources/ai-pilots-failing-mit-challenges-and-solutions>
- [7] The State of AI: How Organizations Are Rewiring to Capture Value. McKinsey, 2025.
<https://www.mckinsey.com/capabilities/quantumblack/our-insights/the-state-of-ai>
- [8] Deploying Agentic AI with Safety and Security: A Playbook for Technology Leaders. McKinsey Risk & Resilience, 2025.
<https://www.mckinsey.com/capabilities/risk-and-resilience/our-insights/deploying-agentic-ai-with-safety-and-security-a-playbook-for-technology-leaders>
- [9] Taxonomy of Failure Modes in Agentic AI Systems. Microsoft AIRT, 2025.
<https://cdn-dynmedia-1.microsoft.com/is/content/microsoftcorp/microsoft/final/en-us/microsoft-brand/documents/Taxonomy-of-Failure-Mode-in-Agentic-AI-Systems-Whitepaper.pdf>
- [10] AI Gone Wrong: Errors, Mistakes, and Hallucinations (2023–2025). Tech.co, 2025.
<https://tech.co/news/list-ai-failures-mistakes-errors>
- [11] McKinsey Technology Trends Outlook 2025. McKinsey, 2025.
<https://www.mckinsey.com/capabilities/mckinsey-digital/our-insights/the-top-trends-in-tech>
- [12] Consumer Chatbot Session Leak Incident. BBC News, July 2025.
<https://www.bbc.com/news/articles/c4g8r34nxeno>
- [13] Enterprise Chatbot Breach Highlights AI Security Blind Spots. CSO Online, August 2025.
<https://www.csoonline.com/article/4043005/enterprise-chatbot-breach-highlights-ai-security-blind-spots-in-customer-facing-systems.html>

Scope & Non-Claim

The ALRI is a governance heuristics which depends on defined/modifyable factors and not a ML generated prediction.

Acknowledgement

The author used OpenAI's ChatGPT (GPT-5) for editorial and technical review assistance under supervision, particularly for refining structure, validating reasoning in formulas (e.g., ALRI), and improving explanatory clarity.

Supplementary literature review and verification were performed using publicly available web and academic sources.

All conceptual models and conclusions remain solely the author's original work.

About the Author

Rajat Pandey has 13 years of experience in the field of Automation (ITPA/RPA) and enterprise AI governance across multiple platforms.